LAB WRITEUP 01 - NETWORK TRAFFIC BASICS (TRYHACKME)

Room	Network Traffic Basics
Platform	TryHackMe - `https://tryhackme.com/room/networktrafficbasics`
Path	Cyber Security 101 / SOC Level 1 - Network Traffic Analysis
Difficulty	Easy
Time to complete	About 45 minutes
Tasks	6

Objective

Understand why SOC teams analyse network traffic, what a packet actually contains, where traffic comes from and goes to inside an organisation, and how traffic can be collected so that it can be investigated later.

Concepts covered

- Network Traffic Analysis (NTA) as a defensive discipline
- Packet structure: headers, payload, encapsulation, fragmentation
- North-south (external) versus east-west (internal) flows
- Common internal and external traffic sources
- Collection methods: logs, full packet capture, network statistics
- Covert channels: DNS tunnelling and command-and-control hiding in normal protocols

---

Task 1 - Introduction

No answer required. The task sets the scope: traffic analysis is how a defender sees what the network is actually doing, rather than trusting what the inventory says should be happening.

Key idea: an alert tells you something happened; the packets tell you exactly what happened, between which two hosts, and in which direction.

Task 2 - What is the purpose of Network Traffic Analysis?

Question	Answer	Reasoning
Which technique does the network purpose described here detect - hiding command-and-control inside ordinary DNS?	DNS tunneling	DNS is almost always allowed through firewalls, so attackers encode C2 instructions or stolen data into DNS query names or TXT responses. Traffic analysis spots the unusually long, high-entropy names and abnormal query rates that normal DNS never produces.

Why this matters: it is one of the clearest examples of protocol misuse - nothing is "vulnerable", the protocol is simply being used for something it was never designed for, which is exactly the kind of behaviour rules and signatures struggle to catch.

Task 3 - What network traffic can we observe?

Question	Answer	Reasoning
Size of the ZIP attachment in the example HTTP response	10485760 bytes	The captured `Content-Length` field of the response holds the object size. 10485760 bytes is exactly 10 MB - a file size worth flagging when it appears in a download that nobody expected.
Which evasion technique do attackers use to try to evade an IDS?	Fragmentation	The malicious payload is split into many small IP/TCP fragments. A signature looking for one contiguous pattern never matches, unless the IDS reassembles the fragments first.
Which TCP header field can be used to detect session hijacking?	Sequence number	A hijacker must inject packets with a forged sequence/acknowledgement number. Monitoring for the sequence to jump backwards or for out-of-window values exposes the injection.
Name of the technique used to smuggle C2 commands via DNS	DNS tunneling	Commands are encoded into DNS labels or returned in TXT responses, so the traffic looks like ordinary name resolution.

What the packet view actually gives you: the HTTP example shows why full packet capture is so valuable - headers tell you who talked to whom and how much data moved, while the body is where the evidence of malware downloads, credentials and exfiltration lives.

Task 4 - Network Traffic Sources and Flows

Question	Answer	Reasoning
Which category of devices generates the most traffic in a network?	Endpoint devices	Servers, desktops, laptops, VMs, phones and IoT devices originate and terminate the bulk of the data. Intermediary devices such as switches and routers only forward it and add a little management traffic of their own.
Before an SMB session can be established, which service must be contacted first for authentication?	Kerberos	In a Windows domain the host first authenticates to the Key Distribution Center on the domain controller and receives a service ticket, and only then is the SMB ticket presented for the file share. Seeing Kerberos immediately before SMB across the network is a textbook east-west lateral-movement pattern.
What does TLS stand for?	Transport Layer Security	TLS encrypts application-layer traffic such as HTTPS, which is why so much of an analyst's work is metadata-based: SNI, destination IP, flow size, timing and certificate details.

Flows, in two words each:

- North-south - traffic crossing the perimeter, i.e. internal hosts to the internet and back.
- East-west - traffic between internal hosts, where lateral movement, SMB, RDP and internal scanning live.

Task 5 - How can we observe network traffic?

This task compares three collection approaches and then uses a packet-capture lab to test them.

Collection method	What you get	Cost / limitation
Logs	Metadata about connections and events; long retention for little space	Depends on what the device was configured to log
Full packet capture	Every byte of every packet - payloads included	Very large storage requirement, usually only a few days retention
Network statistics (NetFlow)	Direction, volume and frequency of every flow	No payload, but excellent for spotting beaconing and anomalies

Lab questions

Question	Answer	How it was found
Flag found in the HTTP traffic in scenario 1	THM{FoundTheMalware}	In the simulated capture, paging the packet table to the last page shows the final HTTP `GET` answered `200 OK` with `application/zip` and a size of 10485760 bytes. Expanding that row reveals the body preview, which contains the flag - proving a malware archive was downloaded over HTTP.
Flag found in the DNS traffic in scenario 2	THM{C2CommandFound}	Selecting the link between the switch and the DNS server filters the view to DNS. A UDP DNS response appears as `Standard query response ... TXT c2.tryhackme.thm`. Expanding it shows the TXT data field holding the flag - a C2 command delivered inside a DNS TXT record.

Lesson from the two flags: the first flag is easy to miss because it lives in a response body; the second is easy to miss because it lives in a DNS TXT record rather than in the query name. Both required looking past the packet summary line.

Task 6 - Conclusion

No answer required. The room closes by connecting the pieces: you cannot protect what you cannot see, and traffic analysis is what turns a network diagram into evidence.

Key takeaways

1. Traffic analysis answers the question a log cannot: what was actually on the wire, in which direction, between which hosts.
2. DNS is the most abused protocol because it is always allowed - DNS tunnelling, TXT-record C2 and long random subdomains are the fingerprints to hunt for.
3. Fragmentation is an IDS evasion technique, which is why an IDS must reassemble before matching.
4. TCP sequence numbers are the field that exposes session hijacking.
5. Endpoints generate most traffic, and Windows domain authentication (Kerberos) precedes SMB - that sequence is how lateral movement is spotted.
6. Three ways to observe traffic (logs, full packet capture, flow statistics) trade retention against detail; mature SOCs run all three.